ROALLA



EXECUTIVE OPERATIONAL TECHNOLOGY SECURITY GUIDE

Operational Technology Cybersecurity and Resilience Guide 2026

A decision framework for protecting connected production warehouse and facility operations

Prepared for Canadian owners, boards, chief executives, operations, technology, engineering, maintenance, security, risk, safety and business continuity leaders

Prepared by ROALLA Transformation and Technology Advisory

Status date: 6 October 2026

Purpose

This guide helps leadership govern cyber risk where digital systems interact with physical operations. It connects OT asset visibility, IT OT boundaries, remote access, vulnerabilities, detection, response, recovery, safety, vendor dependency and operational continuity so security improvements reduce risk without creating uncontrolled production disruption.

EXECUTIVE DECISION DASHBOARD

Management View at a Glance

OT cybersecurity is an operational resilience responsibility, not an IT-only project. Management should first establish asset and connection visibility, protect boundaries and privileged access, prepare tested recovery, and sequence technical change under engineering and safety controls.

Executive question	ROALLA view	Decision implication
Do we know what is connected?	**PREPARE**	Create a passive, validated OT asset and connection baseline by site and critical process.
Can vendors reach production?	**DECIDE**	Review every remote path, identity, approval, session, log, expiry and emergency exception.
Are IT and OT separated?	**CONDITIONAL**	Validate boundaries and required flows under controlled engineering change.
Can critical operations recover?	**PREPARE**	Test controller logic, configurations, servers, licences, spares and manual procedures.
What should management authorize?	**PURSUE**	A 90-day OT resilience baseline and priority risk-reduction program.

Recommended Management Posture

Proceed through a small number of explicit decision gates. Preserve evidence as work occurs, separate discovery from implementation, and require each investment to demonstrate value, feasibility, control effectiveness and accountable ownership before scale.

EXECUTIVE DECISION MODEL

The Eight OT Cybersecurity and Resilience Gates

Industrial security decisions must protect confidentiality, integrity and availability while respecting real-time performance, safety, warranty and lifecycle constraints. Uncontrolled security change can be as disruptive as an unaddressed vulnerability.

Stage	Gate	Required conclusion	Decision evidence
01	Governance	OT risk has accountable ownership	Executive mandate, decision rights, risk acceptance and site roles
02	Inventory	Assets and connections are known	Controllers, HMIs, servers, devices, software, owners and lifecycle
03	Architecture	Trust boundaries are designed	Zones, conduits, firewalls, DMZ, services and approved flows
04	Access	Human and machine access is controlled	Identity, privilege, remote vendors, MFA, logging and expiry
05	Vulnerability	Weaknesses are risk-managed safely	Advisories, exposure, compensating controls, testing and exceptions
06	Detection	Abnormal activity can be identified	Logs, network visibility, baselines, alerts and escalation
07	Response	Cyber and operational teams can act together	Playbooks, communications, safety authority and evidence
08	Recovery	Critical operations can be restored	Backups, configurations, spares, priorities, tests and manual modes

Decision Rule

A failed hard gate moves the initiative to Prepare or Monitor. A strong narrative, senior sponsor or attractive market cannot replace missing authority, evidence, delivery capacity or operating control.

SECTION 01

Readiness Framework

Translate ambition into a shared executive view of value, evidence, capability and risk.



Readiness Dimensions

No.	Decision area	Management evidence	Status
01	Governance and criticality	Ownership, sites, processes, safety, risk and priorities	**Confirmed / Developing / Gap**
02	Assets and architecture	Inventory, lifecycle, zones, conduits, protocols and dependencies	**Confirmed / Developing / Gap**
03	Identity and remote access	Accounts, privilege, vendors, MFA, approvals, logging and expiry	**Confirmed / Developing / Gap**
04	Protection and monitoring	Hardening, vulnerability, change, allowlisting, telemetry and alerts	**Confirmed / Developing / Gap**
05	Response and recovery	Playbooks, backups, configurations, spares, exercises and continuity	**Confirmed / Developing / Gap**
06	Third parties and assurance	Contracts, integrators, service, evidence, exceptions and improvement	**Confirmed / Developing / Gap**

Evidence Standard

Assessments should distinguish verified evidence from management confidence. Where evidence is incomplete, record the gap, owner, completion date and decision that depends on it.

STRATEGIC READINESS DEPENDENCIES

What Readiness Depends On

Dependency	Why it matters	Evidence management should expect
Governance	OT risk has accountable ownership	Executive mandate, decision rights, risk acceptance and site roles
Inventory	Assets and connections are known	Controllers, HMIs, servers, devices, software, owners and lifecycle
Architecture	Trust boundaries are designed	Zones, conduits, firewalls, DMZ, services and approved flows
Access	Human and machine access is controlled	Identity, privilege, remote vendors, MFA, logging and expiry
Vulnerability	Weaknesses are risk-managed safely	Advisories, exposure, compensating controls, testing and exceptions
Detection	Abnormal activity can be identified	Logs, network visibility, baselines, alerts and escalation
Response	Cyber and operational teams can act together	Playbooks, communications, safety authority and evidence
Recovery	Critical operations can be restored	Backups, configurations, spares, priorities, tests and manual modes

ROALLA Interpretation

Dependencies should be evaluated as a connected system. A weakness in ownership, data, architecture, delivery or governance can change the economics and risk of an otherwise attractive initiative.

SECTION 02

Detailed Readiness Assessment

Convert executive intent into verifiable requirements, accountable evidence and clear remediation actions.



READINESS CHECKLIST

OT Governance Architecture and Access Readiness

Completion standard Mark Ready only when the supporting evidence has been verified. Assign an evidence owner to every open item.

Gate	Readiness requirement	Ready	Gap	Evidence owner
A01	Executives assign OT cyber risk across operations, engineering, IT, security, safety and site leadership.	☐	☐	_____
A02	Critical processes are ranked by safety, production, quality, environmental and customer impact.	☐	☐	_____
A03	A validated inventory identifies OT hardware, software, firmware, protocols, owners and lifecycle state.	☐	☐	_____
A04	Approved diagrams show IT OT boundaries, zones, conduits, wireless, cloud and external connections.	☐	☐	_____
A05	Required communications are documented and unnecessary paths are denied or scheduled for removal.	☐	☐	_____
A06	Remote vendor access uses approved identities, MFA, least privilege, time limits, monitoring and revocation.	☐	☐	_____
A07	Shared, default, dormant and service credentials are inventoried and controlled with operational safeguards.	☐	☐	_____
A08	Portable media, engineering workstations and maintenance laptops follow controlled connection procedures.	☐	☐	_____
A09	OT changes require engineering, security, safety, testing, rollback and production authorization as appropriate.	☐	☐	_____
A10	Risk acceptance and compensating controls have owners, expiry dates and management review.	☐	☐	_____

READINESS CHECKLIST CONTINUED

OT Detection Response and Recovery Readiness

Completion standard Use Gap to create a dated remediation action and identify the management decision that cannot proceed.

Gate	Readiness requirement	Ready	Gap	Evidence owner
B01	Vulnerability decisions consider exploitability, exposure, criticality, safety, warranty and outage opportunity.	☐	☐	_____
B02	Secure configurations and known-good controller logic, recipes and device settings are retained.	☐	☐	_____
B03	OT network and security monitoring establish normal communications and actionable escalation criteria.	☐	☐	_____
B04	Logs and time synchronization support investigation across OT, IT, physical access and vendor sessions.	☐	☐	_____
B05	Incident playbooks define safety authority, isolation options, production decisions and external communications.	☐	☐	_____
B06	Tabletop and technical exercises include operations, engineering, IT, security, leadership and key vendors.	☐	☐	_____
B07	Backups are offline or protected, complete, versioned and tested for actual restoration.	☐	☐	_____
B08	Recovery priorities, dependencies, spares, licences, media and vendor contacts are current by critical process.	☐	☐	_____
B09	Manual or degraded operating procedures are safe, trained, available and periodically validated.	☐	☐	_____
B10	Management reviews OT risks, incidents, exceptions, lifecycle exposure and resilience improvements routinely.	☐	☐	_____

WEIGHTED EXECUTIVE ASSESSMENT

Readiness Scorecard

Dimension	Weight	Evidence standard	Score	Status
Governance and criticality	20%	Ownership, sites, processes, safety, risk and priorities	__/20	Strong / Developing / Gap
Assets and architecture	20%	Inventory, lifecycle, zones, conduits, protocols and dependencies	__/20	Strong / Developing / Gap
Identity and remote access	15%	Accounts, privilege, vendors, MFA, approvals, logging and expiry	__/15	Strong / Developing / Gap
Protection and monitoring	15%	Hardening, vulnerability, change, allowlisting, telemetry and alerts	__/15	Strong / Developing / Gap
Response and recovery	15%	Playbooks, backups, configurations, spares, exercises and continuity	__/15	Strong / Developing / Gap
Third parties and assurance	15%	Contracts, integrators, service, evidence, exceptions and improvement	__/15	Strong / Developing / Gap
TOTAL	100%	Weighted executive assessment	__/100	Pursue / Prepare / Monitor

Decision Thresholds

Score	Posture	Management decision
75 to 100	**PURSUE**	Proceed to bounded execution subject to no hard-gate failure.
50 to 74	**PREPARE**	Complete a focused readiness plan before major commitment.
0 to 49	**MONITOR**	Resolve foundational gaps before investing further.

A single material hard-gate failure overrides the weighted score. ROALLA also applies judgment where administrative readiness is high but strategic value, adoption or commercial viability is weak.

SECTION 03

Execution and Advisory Roadmap

Reduce the most consequential exposure first while building repeatable governance and recovery capability that respects industrial safety and availability.



Recommended 90 Day Mobilization

Timing	Focus	Key activities	Management output
Days 1 to 15	Govern	Confirm critical sites, processes, owners, risk criteria, safety constraints and evidence access.	Approved OT security mandate
Days 16 to 35	Discover	Validate assets, connections, architecture, remote access, dependencies and lifecycle risks.	OT exposure baseline
Days 36 to 55	Protect	Prioritize boundaries, access, configuration, vulnerability and monitoring improvements.	Owned treatment roadmap
Days 56 to 75	Prepare	Build response, recovery, backup, spares, manual operation and vendor coordination.	Testable resilience plan
Days 76 to 90	Exercise	Run a cross-functional exercise, close critical gaps and approve the next investment gates.	Executive resilience decision

Twelve to Twenty Four Month Path

- Quarter 1: establish governance, criticality, inventory, architecture and priority access controls.
- Quarter 2: improve boundaries, monitoring, vulnerability decisions, backups and incident readiness.
- Quarters 3 and 4: remediate lifecycle risks, exercise sites and embed vendor and change assurance.
- Year 2: mature risk metrics, architecture patterns, recovery evidence and capital renewal planning.

ROALLA ADVISORY MODEL

How ROALLA Can Help

ROALLA coordinates OT resilience as an executive and operating transformation. ROALLA connects plant leadership, engineering, IT, security, safety, integrators, equipment vendors and insurers around a verified fact base and a practical risk-reduction roadmap while qualified specialists validate technical and regulatory matters.

ROALLA workstream	Executive value
OT resilience diagnostic	Establish criticality, assets, architecture, access, vulnerabilities, monitoring and recovery facts.
Governance and risk	Define decision rights, risk criteria, exceptions, site accountability and executive reporting.
Architecture and segmentation	Design zones, conduits, DMZ, required flows and controlled implementation sequencing.
Identity and vendor access	Strengthen named access, MFA, privilege, approval, monitoring, expiry and emergency use.
Lifecycle and vulnerability	Prioritize exposure, compensating controls, outage windows and replacement investments.
Incident and recovery	Develop joint playbooks, backups, restoration, spares, manual operation and exercises.
Vendor and contract assurance	Align integrator access, support, evidence, notification, service and lifecycle obligations.
Ongoing OT assurance	Monitor risks, exceptions, incidents, architecture change and resilience evidence.

Recommended Initial Mandate

- Four-week OT cybersecurity and resilience diagnostic for one priority site.
- Validated critical-process, asset, connection, access and recovery fact base.
- Prioritized risk treatment and lifecycle roadmap with owners and outage dependencies.
- Executive tabletop exercise and 90-day resilience mobilization plan.

CONTROL FRAMEWORK

Key Risks and Controls

Risk	Exposure	ROALLA control
Unknown exposure	Unmanaged assets or connections bypass control.	Build passive inventory and validate it with site owners.
Flat network	One compromise can move broadly across operations.	Engineer zones, conduits, DMZ and approved flows carefully.
Vendor access	Persistent or shared access creates an external path.	Use named, approved, monitored and expiring sessions.
Unsafe patching	Security change disrupts control or warranty.	Assess risk, test, schedule and retain compensating controls.
Silent compromise	Activity is not detected until production fails.	Establish OT-aware monitoring and escalation.
Response conflict	IT containment creates operational or safety harm.	Use joint playbooks and explicit decision authority.
False backup	Files exist but cannot restore the process.	Test full restoration with dependencies and licences.
Legacy lifecycle	Unsupported systems accumulate unmitigated risk.	Use isolation, compensating controls and funded replacement plans.

Professional Advice

Qualified legal, privacy, security, tax, accounting, employment and regulatory advisors should validate matters within their professional scope. ROALLA coordinates those inputs with technology strategy, architecture, commercialization, governance and transformation decisions.

OFFICIAL EVIDENCE BASE

Selected Official Sources

These sources support the management principles summarized in this guide. Standards, laws, guidance and organizational obligations continue to evolve and must be confirmed for the specific context before acting.

Canadian Centre for Cyber Security operational technology guidance. Official source — Canadian guidance for protecting operational technology used in manufacturing and other industrial environments.

Canadian operational technology threat bulletin. Official source — Current threat perspective and defensive guidance for exposed OT, boundaries, remote access and segmentation.

NIST Guide to Operational Technology Security. Official source — Risk-based security guidance for industrial control systems and other operational technology.

NIST Cybersecurity Framework 2.0. Official source — Outcome-based framework for governing and managing cybersecurity risk.

NIST cybersecurity for smart manufacturing systems. Official source — Cybersecurity measurement, implementation and monitoring considerations for connected manufacturing systems.

Canada Advanced Manufacturing Cluster. Official source — Official overview of NGen priorities including automation, machine learning, cybersecurity and SME technology adoption.

Advisory Disclaimer

This ROALLA guide is a strategic readiness and marketing document. It is not a certification, audit opinion, legal opinion, privacy opinion, security assurance, investment recommendation or guarantee of results. Management must validate current obligations, company facts and professional advice before making material decisions.